studocu

2022.gis - Primer examen 2022

Garantia de la Informació i Seguretat (Universitat Autònoma de Barcelona)

Scan to open on Studocu

Studocu is not sponsored or endorsed by any college or university
Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

Nom:	NIU:

Question:	1	2	3	4	5	6	7	8	9	10	Total
Points:	5	10	6	7	7	10	10	15	15	15	100
Score:											

Garantia de la Informació i Seguretat

Examen Parcial 1 (21/03/2022)

- *Cada resposta ha de ser degudament justificada (de manera breu i concisa).*
- *No es pot tenir cap dispositiu electrònic i/o de comunicació (telèfon mòbil, smartwatch, tablet, calculadora, etc.) durant la realització de l'examen. Tal com indica la guia docent, tenir un d'aquests dispositius durant l'examen (estigui encès o apagat) comporta una qualificació de zero sense possibilitat de recuperació.*
- *No es poden fer preguntes durant la realització de l'examen. Qualsevol observació o dubte que tingueu respecte a l'enunciat el podeu fer constar junt amb la resposta.*

1. (5%) Quina diferencia hi ha entre un atac actiu i un atac passiu?, dona un exemple de cada cas.

2. (10%) A CVSSv3, en referència a la mètrica base, respon a les següents preguntes:
   (a) Digues què mesura el vector d'atac (Attack Vector, AV). Quin valor de l'AV fa que l'score final sigui més alt? Per què?

   (b) Digues què mesura el Scope (S). Quin valor del S fa que l'score final sigui més alt? Per què?

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

3. (6%) Quins són els 3 principals estats del cicle de vida d'una vulnerabilitat? Esmenta els 3 cicles i dona una breu descripció de cadascun.

4. (7%) Un atac amb diccionari en clar té més èxit (és més efectiu en termes generals) en l'esquema de passwords que fa servir Windows (sense salt) o en el que fa servir Linux (amb salt)? Justifica la resposta.

5. (7%) Què és i què indica el *False Acceptance Rate* (FAR) d'un sistema biomètric? Com es comporta aquest índex a mesura que augmentem la precisió (sensibilitat o exactitud) del sistema i per què?

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

6. (10%) Digueu si les següents afirmacions són certes o falses i justifiqueu breument per què.
   (a) CVSS està format per tres grups de mètriques: base, temporal i de processament.

   (b) CVE és una base de dades de vulnerabilitats.

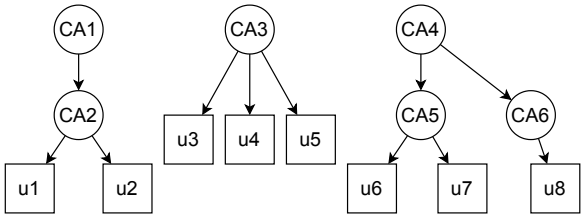
   (c) En la generació d'un password d'un sol ús (*One Time Password*, OTP) basat en temps, es fa servir una mesura de temps i un comptador per generar el password.

   (d) Una vulnerabilitat de dia zero (*0-day vulnerability*) és una vulnerabilitat per la qual ja existeix una solució oficial i per tant els atacants disposen de 0 dies per fer l'atac.

   (e) En CVSS, el requeriment de confidencialitat (*Confidentiality Requirement*, CR) que forma part de la mètrica d'entorn, mesura l'impacte que té un possible atac que exploti la vulnerabilitat, sobre la confidencialitat del sistema.

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

7. (10%) A continuació podem veure tres esquemes de certificació independents. Cada fletxa representa un certificat que va de l'emissor al *subject*.



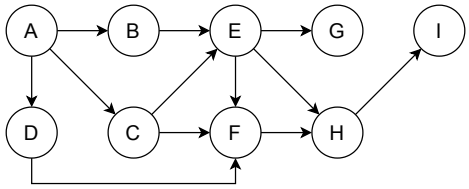
De forma simplificada, representem un certificat amb *Issuer* i *Subject*. P. ex. de la forma:

Issuer	$CA3$
Subject	$u3$

Digues quins certificats caldrien per fer que els dos esquemes de certificació poguessin interactuar seguint el model de confiança conegut com a *cross-certification* (certificació creuada). No cal que mostreu els certificats que emet cada PKI per funcionar de forma independent, només heu de posar els que permeten implementar la certificació creuada. (Justifiqueu la resposta)

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

8. (15%) En la figura següent veiem els certificats emesos fent servir PGP. Cada fletxa simbolitza un certificat on l'emissor és el node origen de la fletxa i el subject el node destí.



Assumim que nosaltres som l'usuari/ària A, i hem assignat un nivell de trust FULL a l'usuari/ària B i un nivell de trust MARGINAL als usuaris/es C, D, E, i F. Pels casos següents, cal que ompliu la taula amb el nivell de validesa (*validity*) de cada clau i una breu justificació de per què heu assignat aquest nivell (una resposta sense justificació no tindrà cap qualificació).

(a) Suposem que tenim la següent política de PGP: perquè una clau sigui vàlida ha d'estar signada per una clau d'un usuari amb nivell de trust FULL, o dos usuaris amb nivell de trust MARGINAL. El camí de certificació no pot ser major de 4.

Clau	*Validity*	*Justificació*
B		
C		
D		
E		
F		
G		
H		
I		

(b) Feu el mateix però ara amb la següent política de PGP: perquè una clau sigui vàlida ha d'estar signada per una clau d'un usuari amb nivell de trust FULL, o tres usuaris amb nivell de trust MARGINAL. El camí de certificació no pot ser major de 3.

Clau	*Validity*	*Justificació*
B		
C		
D		
E		
F		
G		
H		
I		

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

9. (15%) Partim d'un esquema de passwors que no fa servir salt, on els passwords són PINs de 3 dígits decimals. Coneixem que la funció per xifrar o hashejar els passwords és la següent: donat un password $d_1d_2d_3$, es xifra com $H(d_1d_2d_3) = p_1p_2p_3p_4p_5p_6$, on $p_1 = d_1; p_2 = d_1 + 1; p_3 = d_2; p4 = d_2 + 1; p_5 = d_3; p_6 = d_3 + 1$, i totes les sumes es fan mòdul 10. Assumim que aquesta funció és una funció unidireccional (no invertible).

   Fem servir una funció de reducció R tal que $R(p_1p_2p_3p_4p_5p_6) = d_1d_2d_3$, on $d_1 = p_2; d_2 = p_4; d_3 = p_6$ per tal de generar una *rainbow table*. Exemples de funció de xifrat i reducció són: $H(123) = 122334; H(111) = 121212; H(528) = 562389; H(939) = 903490$, $R(123456) = 246; R(111111) = 111; R(634946) = 396; R(989832) = 882$.

   La *rainbow table* resultant és:

123	→	566778
444	→	898989
264	→	670189
923	→	346778

   Com farem per trobar el password de *root* sabent que xifrat és 347856, fent servir la rainbow table? (indiqueu els passos que faríeu per trobar-ho i quin resultat obteniu).

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

10. (15%) Considerem el handshake del protocol TLS 1.3 tal com l'hem estudiat a l'assignatura i fem servir la notació següent:

R_S	Random value generated by user S
$cert_S$	Public key certificate of user S
PK_S, SK_S	public key pair of user S, where PK denotes the public key and SK the private key
CP	Crypto proposed (set of cryptographic parameters proposed)
CS	Crypto selected (set of cryptographic parameters selected)
p, g	Prime (p) and generator (g) for Diffie-Hellman key exchange
msg	Message including all previous messages exchanged in the protocols until the current one (the transcript hash).
$E_{PK_A}(m)$	Encryption of message m with public key of user A PK_A.
$E_K(m)$	Encryption of message m with symmetric key K.
Kh_A	Symmetric handshake key for user A.
Kf_A	Handshake finished key for user A.
$Sig_{SK}(m)$	Digital signature of message m with private key SK.
$HMAC(K, m)$	HMAC with key K applied to message m.

Veiem el handshake entre client (C) i servidor (S), següent:

$C \to S$	ClientHello	$R_C, CP, g^c \mod p$
$S \to C$	ServerHello	$R_S, CS, g^s \mod p$
$S \to C$	EncryptedExtensions	E_{Kh_S}(EncryptedExtensions)
$S \to C$	CertificateRequest	E_{Kh_S}(CertificateRequest)
$S \to C$	Certificate	$E_{Kh_S}(cert_S)$
$S \to C$	Finished	$E_{Kh_S}(HMAC(Kf_S, msg))$
$C \to S$	Certificate	$E_{Kh_C}(cert_C)$
$C \to S$	Finished	$E_{Kh_C}(HMAC(Kf_C, msg))$

Sabem que es vol fer autenticació mútua.

(a) Quin problema presenta el protocol tal qual està descrit? Quin problema de seguretat pot tenir o quin/s atac/s es poden fer?

(b) Es demana ara que rectifiquis el protocol perquè sigui correcte. Si sobra algun missatge digues quin. Si falta algun missatge digues quin, i quin contingut tindrà.

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)

(Pàgina en blanc per anotacions i com a complement a l'espai de respostes)

Downloaded by pablo colao cintas (pablowilco0909@gmail.com)